

CYBER.SOHO

Educational Hub

420-D01-AB • CYB-01

Cyber.SoHo Educational Hub

*From the Industry to the Classroom
Building the IT's Future, Today and Together!*

DAYS 08–11

Detect and Analyze Anomalies

Preventive Surveillance in Cybersecurity

5 hours lecture • 9 hours in-class lab • 4.5 hours home

What You Will Learn

Four lectures across four days

1. **Day 08** — Proper use of monitoring tools
2. **Day 09** — Methodical analysis: traffic, files, event logs
3. **Day 10** — Efficient detection and rigorous analysis
4. **Day 11** — Correct identification of incidents

Reference frameworks

- **EZ01** elements 4.1 through 4.5
- **NIST SP 800-61r2** (Incident Handling Guide)
- **MITRE ATT&CK** (tactics, techniques, sub-techniques)

Agenda at a Glance

Day-by-day plan and submission gate

Day	Lecture	Hands-on
08	Proper use of monitoring tools	Activity / Demo
09	Methodical analysis	Lab 4
10	Efficient detection	Lab 5
11	Correct identification of incidents	Lab 5 cont.

- All labs feed the **Course Procedure Manual** (continuous project, 10 % of grade)
- Lab 4 + Lab 5 due **June 13 • 23:59 EST** via OmniVox LEA Dropbox

LECTURE 1

Proper Use of Monitoring Tools

1 hour · 4 sub-sections

What "Proper Use" Means

A tool used improperly is worse than no tool

- It **gives false confidence** — you think you are watching
- It **produces silent blind spots** — gaps invisible on the dashboard
- It **wastes attention** owed to real signals

Proper use rests on three pillars

1. **Right tool** for the right question
2. **Right configuration** — promisc mode, time sync, log channels
3. **Right baseline** — without it, every alert is noise

Five Families of Monitoring Tools (1/2)

Lane definitions

Family	Scope	Example Tools
Packet capture	Bytes on the wire	Wireshark, tshark
NIDS	Patterns on the wire	Suricata, Zeek, Snort
EDR	Process / file on host	Defender, CrowdStrike, Sysmon
SIEM	Aggregated logs, correlation	Splunk, Elastic, Wazuh
Infra Monitor	Availability / metrics	Nagios, Prometheus, Zabbix

Five Families of Monitoring Tools (2/2)

Picking the right family

- What flew across the wire? → packet capture or NIDS
- What happened on this host? → EDR
- Did service X go down? → infra monitor
- Correlate across 200 sources? → SIEM
- Slow trend over weeks? → SIEM + infra monitor

Anti-pattern • do not do this

- Using the **SIEM** for forensic packet replay
- Using **Wireshark** for SLA reporting
- Using **infra-monitor** uptime checks to detect a breach

Baseline Before Alert

Without a baseline, "anomaly" has no meaning

- An anomaly is a **deviation from the expected**
- The expected must be **measured**, not assumed

Time-of-day percentile baseline

- Compute **p50 (median)** and **p95** for the metric, **per hour of day**
- Alert only when the observation **exceeds the p95** for that hour
- A spike at 09:00 is normal; the same spike at 02:00 is suspicious

What to baseline first

1. DNS queries / min per host
2. Outbound bytes / min per host
3. Failed logins / min per account
4. New process names / day per host

Tool Hygiene Checklist

Five items, checked on a schedule

Check	Why it matters
NTP sync	Without aligned clocks, you cannot correlate logs from different hosts
Disk free	A full disk silently rotates evidence — looks like attacker cover-up
Parser version	Out-of-date parser silently fails to match real traffic
Promiscuous bit	Sensor with promisc OFF sees only its own traffic
Canary alert	A test event that must traverse the whole pipeline daily

- **Cadence:** Hourly → disk · Daily → NTP, canary · Weekly → parser · On reboot → promisc

“

A monitoring tool is only as good as its baseline, its configuration, and the hygiene check that proves it is alive.

LECTURE 2

Methodical Analysis Traffic • Files • Event Logs

1.5 hours • 4 sub-sections

The Three Lanes Principle

Every investigation touches three lanes

1. **Lane 1 — Traffic:** who talked to whom, how long, how many bytes
2. **Lane 2 — Files:** what landed on disk, when, hash and signature
3. **Lane 3 — Event Logs:** what the OS and apps wrote down

Confidence equals lane agreement

- **1 lane** = curiosity, keep collecting
- **2 lanes agree on the same IoC** = open an investigation
- **3 lanes agree** = declare an incident

Five-Step Traffic Loop (1/2)

Same five steps, every pcap, every time

1. **Conversation map** — who is talking to whom?
2. **Protocol mix** — what is on the wire (TLS, DNS, HTTP, weird)?
3. **Throughput timeline** — when do the bytes flow?
4. **Endpoint reputation** — peers known-good, known-bad, unknown?
5. **Decode the suspect flow** — what did the session actually say?

Five-Step Traffic Loop (2/2)

Per-step artifact for the report

Step	Deliverable
Conversation map	Top-10 conversation table by bytes
Protocol mix	Protocol hierarchy snapshot
Throughput timeline	I/O graph + burst start/end times
Endpoint reputation	External IPs + WHOIS / VirusTotal results
Decoded flow	Annotated stream excerpt + plain-English summary

- **Rule of thumb:** no more than 10 minutes per step on first pass
- Loop a **second time only** on the suspect flow

File Analysis • Timestamps & Hashes

NTFS \$STANDARD_INFORMATION — the M-A-C-B model

M	Modified	File content changed
A	Accessed	File opened for read
C	Changed	MFT metadata changed (ACL, attribs)
B	Born	File created on this volume

Red flag • classic dropper-landing signature

- All four timestamps within ~1 second
- Parent folder contains files born much earlier

Mandatory checks • SHA-256 • Authenticode signer • VirusTotal URL only

Event Logs • Windows + Sysmon

Top event IDs to know cold

ID	Meaning	Red flag
4624	Logon success	Type 10 (RDP) after-hours from new IP
4625	Logon failure	>10 failures / minute = spray
4688	Process created	Office app spawning cmd / PowerShell / mshta
1102	Audit log cleared	Almost always malicious; freeze host
Sysmon 1	Process create	Parent = Office, child = scripting host
Sysmon 10	Process access	TargetImage = lsass.exe = credential dump

- Pair every **success** (4624) with the **failures** that preceded it (4625)
- Pair every alert with the **command line**, not just the binary name

“

Three independent lanes — traffic, files, logs — converging on the same indicator turn a hunch into evidence. Count the lanes; that is your confidence.

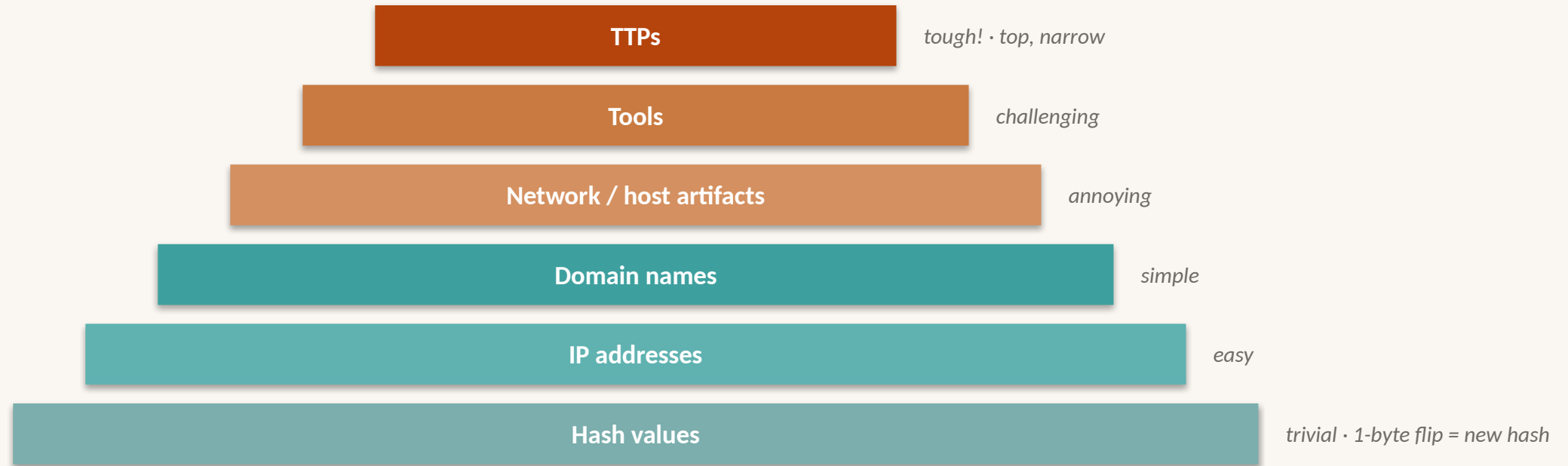
LECTURE 3

Efficient Detection Rigorous Analysis

1 hour · 3 sub-sections

Pyramid of Pain (1/2)

Bianco's hierarchy — how much it hurts the attacker to change



Pyramid of Pain (2/2)

Detection-as-Code and the 80/20

- **Sigma** — vendor-neutral detection language, version-controlled in Git
- Treat detections as **code**: pull request, peer review, test data
- **80/20 rule**: 20 % of techniques cover 80 % of intrusions
- Start with: phishing chains, credential dumping, lateral movement, persistence, exfiltration

What to ship first

- A handful of **high-up-the-pyramid** rules that you trust
- Beats a thousand low-fidelity hash matches you ignore

HE-UH-C Discipline (1/2)

Four questions for every anomaly

1. **H — Happened:** what did we observe? (no theory)
2. **E — Evidence:** which artifacts support it?
3. **UH — Un-evidence:** what would prove us wrong?
4. **C — Confidence:** 0 – 100, with a reason

Why it works

- Forces plain observable writing in **H**
- Forces named artifacts in **E**
- Forces a falsifiability check in **UH** — the most-skipped step
- Forces a number in **C** that drives the next action

HE-UH-C Discipline (2/2)

Confidence thresholds and the action they trigger

Confidence	Meaning	Action
< 50 %	Weak / one lane	Keep collecting
50-74 %	Building	Note in shift handover
75-89 %	Strong	Escalate to IR lead
≥ 90 %	Confirmed	Declare incident

- **Discipline:** refuse to skip a level — every escalation cites the artifacts that justify it

See fast. Decide slow. Type carefully.

- **See fast** — efficient detection: pyramid-aware rules, daily canary
- **Decide slow** — rigorous analysis: HE-UH-C with un-evidence filled in
- **Type carefully** — your report is the evidence; words matter

Common failure modes

- Fast eyes + fast hands = noisy escalations
- Slow eyes + slow hands = missed dwell time
- **Fast eyes + slow hands = professional SOC**

“

*Detection is cheap; rigorous analysis is rare. The HE-UH-C worksheet is not bureaucracy — it is the *un-evidence* row that protects you from your own confirmation bias.*

LECTURE 4

Correct Identification of Incidents

1 hour · 3 sub-sections

NIST SP 800-61r2 Terminology (1/2)

Four nested categories — widest to narrowest



Rough survival rates: 100 % events → ~10 % adverse → ~1 % incidents → < 0.1 % breaches

NIST SP 800-61r2 Terminology (2/2)

Why the funnel matters

- Calling everything an "incident" exhausts the IR team and dulls the alarm
- Calling a real incident an "event" loses dwell-time minutes that matter
- Use the **right word** so the **right people** wake up

Canadian regulator triggers (breach level)

- **PIPEDA federal** — Office of the Privacy Commissioner of Canada (OPC)
- **Quebec Law 25** — Commission d'accès à l'information (CAI)
- **CCCS** — Canadian Centre for Cyber Security (voluntary technical share)
- **RCMP NC3** — criminal report path

Three Confirmation Gates (1/2)

All three must pass before "incident" is on your lips

1

Reproducibility

Can a second analyst replay the artifacts and reach the same observation?

2

Persistence

Does the behaviour persist across log rotation, reboot, and shift change?

3

Plausibility

Have you actively tried to disprove a benign explanation?

Scoring · each gate: 0 (no), 1 (partial), 2 (yes) · max total = 6

Three Confirmation Gates (2/2)

Score-to-action map

Total	Action
6 / 6	Declare incident; hand to IR
5 / 6	Declare incident; document the weak gate
3 - 4 / 6	Investigate further; target the weakest gate next
≤ 2 / 6	Stay in monitoring; do not waste IR time

- **Most-skipped gate: Plausibility** — analysts rarely try hard enough to disprove their own theory
- **The cure:** write the benign hypothesis *before* you investigate

One-Page Incident Summary (1/2)

Seven fields, one page, every time

1. **When** — UTC + local
2. **What happened** — one sentence, observable
3. **Where** — asset / network zone
4. **Who is affected** — user / dept / external
5. **How it was detected** — tool + signal
6. **Category** — Event / Adverse / Incident / Breach
7. **Next action** — owner + deadline

One-Page Incident Summary (2/2)

Discipline rules

- **One sentence** for "What" — if you need three, you do not understand it yet
- **Named human** for owner — not "the SOC", not "someone"
- **Clock time** for deadline — not "ASAP", not "soon"
- **NIST category** — not a feeling, a label from the funnel

Why a one-pager

- Executives read one page; they do not read ten
- The page survives the handover; your memory does not

“

Use the right word. Pass three gates. Fit it on one page. Words drive who wakes up, gates protect you from escalation theatre, and the one-pager survives the handover when you go off-shift.

Cross-Lecture Synthesis

The full discipline, in one picture



Tools → Lanes → Confidence → Category → Action

One sentence, four days.

What to Practise This Week

Hands-on, in order

1. **Day 08 Activity** — tool selection + first capture
2. **Lab 4** — 3-lane triage on captured pcap + files + evtx
3. **Lab 5** — live attack-chain detection with MITRE mapping
4. **Lab 5 cont.** — formal incident report + kill-chain diagram

Reading

- Bejtlich — *The Practice of Network Security Monitoring*
- Chappell — *Wireshark Workbook 1*
- Bianco — *Pyramid of Pain* (2013) · **NIST SP 800-61r2**

Submission Logistics

How and when

- **Where:** OmniVox LEA Dropbox
- **When:** June 13 • 23:59 EST
- **Penalty:** 10 % per calendar day late
- **Format:** PDF report + screenshots + filled HE-UH-C worksheets
- **Naming:** 420-D01-AB_CYB-01_LastName_Lab<N>.pdf

Academic-integrity reminder

- Lab activity stays **inside the lab range**
- VirusTotal lookups by **URL only** — never upload a sample

Selected References

Standards and frameworks

- **NIST SP 800-61r2** — Computer Security Incident Handling Guide
- **MITRE ATT&CK** — Enterprise matrix
- **Sigma** — Generic Signature Format for SIEM systems
- **PIPEDA · Quebec Law 25** — Canadian privacy obligations

Tools referenced

- Wireshark · Zeek · Suricata · Snort
- Sysmon · Windows Event Log · auditd
- Splunk · Elastic · Wazuh · VirusTotal (URL lookups only)

Disclaimer and Intellectual Property

Cyber.SoHo Educational Hub — sole creator and owner

- All material © Cyber.SoHo · all rights reserved
- Lab activity is permitted **only inside the assigned lab range**

Activity outside the range violates:

- Spanish Ley Orgánica 10/1995
- EU Directive 2013/40/EU
- Canadian Criminal Code s.342.1
- US Computer Fraud and Abuse Act (CFAA)

THANK YOU

From the Industry to the Classroom

Building the IT's Future, Today and Together!

Cyber.SoHo Educational Hub

Course 420-D01-AB · Cohort CYB-01

Days 08–11 · Detect and Analyze Anomalies